

Práctica. CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Instrucciones. Elaborar una aplicación de PHP que permita ejemplificar la vulnerabilidad Exposición de información confidencial a un actor no autorizado un servidor Web.

1. Sigue las instrucciones de la práctica en la siguiente página.
2. Crea un reporte de práctica en un **archivo de Word** con una portada con tu nombre. Guárdalo con el nombre **NombreAlumno_CWE-200.docx**.
3. Coloca **las siguientes capturas de pantalla**, cada una con una **descripción textual** arriba de la captura.
 - a. Coloca la captura de pantalla de la salida de la página **index.php** que lee el correo electrónico para la autenticación por e-mail.
 - b. Coloca la captura de pantalla de tu código fuente en Visual Studio Code del archivo **index.php**.
 - c. Coloca la captura de pantalla del correo electrónico enviado a tu bandeja de correo electrónico.
 - d. Publica tu código fuente en un proyecto público de GitHub. **Coloca la URL** del código fuente publicado en GitHub.
4. Sube tu reporte de práctica en un archivo Word a la actividad en Eminus.

Prerrequisitos

1. Esta práctica tiene como prerrequisito tener instalado el software **Visual Studio Code** con la extensión para PHP.
Puede seguir las instrucciones de cómo instalar Visual Studio Code desde la práctica [Instalación de Visual Studio Code](#).
2. Esta práctica tiene como prerrequisito tener instalado el intérprete de PHP en su equipo.
Puede seguir las instrucciones de cómo instalar PHP desde la práctica [Instalación de PHP](#).
3. Esta práctica tiene como prerrequisito **contar con una cuenta activa** de GitHub en <https://github.com/>.
Puede seguir las instrucciones de cómo crear una cuenta de GitHub desde la práctica [Crear cuenta de GitHub](#).
4. Puede seguir las instrucciones de cómo publicar un proyecto en Visual Studio Code a GitHub desde la práctica [Como publicar un proyecto a GitHub desde Visual Studio Code](#).

Instrucciones

Hay muchos tipos diferentes de errores que introducen exposición de información. La gravedad del error puede variar ampliamente, según el contexto en el que opera el producto, el tipo de información confidencial que se revela y los beneficios que puede brindar a un atacante. En este ejemplo, al no realizar una validación de entrada apropiada, produce que un atacante pueda realizar la autenticación por correo electrónico sobre una cuenta de otro usuario víctima.

A. Crear el programa

1. Asegúrese de contar con una carpeta de trabajo en **C:\codigo**. Si aún no ha creado la carpeta **C:\codigo** hágalo antes de continuar.
2. Seleccione **Archivo > Abrir carpeta** en el menú principal.
3. En el cuadro de diálogo **Abrir carpeta**, cree una carpeta en la ruta **C:\codigo\ps\cwe-200** y selecciónela. Luego haga clic en Seleccionar carpeta.
4. El nombre de la carpeta se convierte en el nombre del proyecto y el nombre del espacio de nombres de forma predeterminada. Agregará código más adelante en el tutorial que asume que el espacio de nombres del proyecto es **cwe-200**.
5. Vamos a simular una página de inicio de sesión especial, donde la entrada es mediante el correo electrónico institucional. Cree un nuevo archivo llamado **login.php**. Escriba el siguiente código.

```
<?php
session_start();
session_destroy();
?>

<!DOCTYPE html>
<html lang="es">

<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <link rel="icon" href="data:;base64,iVBORw0KGgo=" />
  <title>Inicio de sesión</title>
  <link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.2/dist/css/bootstrap.min.css">
  <link rel="stylesheet" href="estilos.css">
  <script defer src="login.js"></script>
</head>

<body>
  <div class="contenedor-login mx-4">
    <h1 class="h3 text-center text-success">Universidad Veracruzana</h1>
    <h2 class="h5 text-center text-muted">Programación Segura</h2>
    <form method="post">
      <div class="card mx-auto mt-3">
        <div class="card-header">Inicio de sesión</div>
        <div class="card-body">
          <div class="mb-3">
            <label for="email" class="form-label">Correo electrónico</label>
            <input type="text" class="form-control" id="email" name="email" placeholder="cuenta@uv.mx">
            <div class="small">Solo se permite el acceso con cuentas UV.</div>
            <span class="text-danger d-none">No es un correo válido institucional.</span>
          </div>
        </div>
        <div class="card-footer text-center">
```

```
        <button id="submit" type="submit" class="btn btn-primary">Siguiente</button>
      </div>
    </div>
  </form>
</div>
</body>
</html>
```

6. Observe el inicio del código. Utilizar sesiones en el servidor junto con cookies en el cliente, es una práctica muy común para el manejo del estado, no solo en PHP, sino en la mayoría de lenguajes. Esto se llama comúnmente **Cookie Auth**.
7. Ahora vamos a agregar la hoja de estilos que usa este archivo. Cree un nuevo archivo llamado `estilos.css`. Escriba el siguiente código.

```
.contenedor-login {
  margin-top: 50px;
  display: grid;
  place-items: center stretch;
}
.contenedor-login .card {
  max-width: 500px;
}
```

8. También vamos a agregar el código de cliente que usa este archivo. Cree un nuevo archivo llamado `login.js`. Escriba el siguiente código.

```
// Variables
let form = document.querySelector('form');
let email = document.querySelector('#email');
let msg = document.querySelector('.text-danger');
let submit = document.querySelector('#submit');

form.addEventListener('submit', (e) => {
  e.preventDefault();
  [email, submit].forEach(elemento => {
    elemento.setAttribute("disabled", "");
  });

  if (!email.value.endsWith('@uv.mx')) {
    msg.classList.remove('d-none');
    [email, submit].forEach(elemento => {
      elemento.removeAttribute("disabled");
    });
    return;
  }

  fetch("https://correofeiapi.azurewebsites.net/correo", {
    method: "POST",
    body: JSON.stringify({
      correo: email.value,
    }),
    headers: {
      "Content-type": "application/json; charset=UTF-8"
    }
  }).then(json => {
    [email, submit].forEach(elemento => {
      elemento.removeAttribute("disabled");
    });
  });
});
```

```
});  
document.location = 'codigo.php'  
});  
});
```

9. Después de solicitar el correo electrónico, vamos a crear una página llamada `codigo.php` donde se coloca el código secreto. Escriba el siguiente código.

```
<?php  
session_start();  
if ($_SERVER['REQUEST_METHOD'] === 'POST') {  
    if ($_POST['codigo'] == '7824') {  
        $_SESSION['codigo'] = $_POST['codigo'];  
        header('Location: index.php');  
    }  
}  
?  
<!DOCTYPE html>  
<html lang="es">  
  
<head>  
    <meta charset="UTF-8">  
    <meta name="viewport" content="width=device-width, initial-scale=1.0">  
    <link rel="icon" href="data:;base64,iVBORw0KGgo=" />  
    <title>Inicio de sesión</title>  
    <link rel="stylesheet"  
href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.2/dist/css/bootstrap.min.css">  
    <link rel="stylesheet" href="estilos.css">  
</head>  
  
<body>  
    <div class="contenedor-login mx-4">  
        <h1 class="h3 text-center text-success">Universidad Veracruzana</h1>  
        <h2 class="h5 text-center text-muted">Programación Segura</h2>  
        <form method="post">  
            <div class="card mx-auto mt-3">  
                <div class="card-header">Inicio de sesión</div>  
                <div class="card-body">  
                    <div class="mb-3">  
                        <label for="codigo" class="form-label">Código de seguridad</label>  
                        <input type="text" class="form-control" name="codigo" placeholder="Escriba  
el código de seguridad">  
                        <?php if (isset($_POST['codigo'])) : ?>  
                            <span class="text-danger">Código incorrecto</span>  
                        <?php endif; ?>  
                    </div>  
                </div>  
                <div class="card-footer text-center">  
                    <a href="login.php" class="btn btn-secondary">Regresar</a>  
                    <button id="submit" type="submit" class="btn btn-primary">Entrar</button>  
                </div>  
            </div>  
        </form>  
    </div>  
</body>  
</html>
```

10. Agregue la página de inicio de su aplicación. Cree un nuevo archivo llamado `index.php`. Escriba el siguiente código.

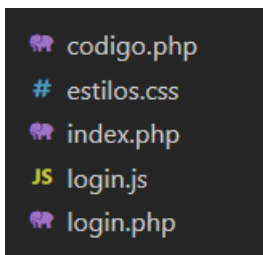
```
<?php
session_start();
if (!isset($_SESSION['codigo'])) {
    echo "<p>No tiene permiso de ver esta página. <a href='login.php'>Iniciar sesión</a></p>";
    exit();
}
?>
<!DOCTYPE html>
<html lang="en">

<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="icon" href="data:;base64,iVBORw0KGgo=" />
    <title>Página protegida</title>
    <link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.2/dist/css/bootstrap.min.css"
rel="stylesheet">
</head>

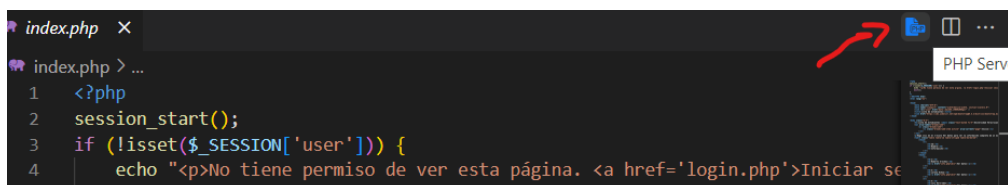
<body class="container mt-4">
    <h2>Sitio protegido <small class="text-muted fs-5">Universidad Veracruzana</small></h2>

    <div class="h-100 mt-5 p-5 bg-body-tertiary border rounded-3">
        <h2>Programación segura</h2>
        <p>Bienvenido a este sitio protegido por correo electrónico y un código de acceso.</p>
        <a href="login.php" class="btn btn-outline-secondary" type="button">Cerrar sesión</a>
    </div>
</body>
</html>
```

11. Debería contar con cinco archivos en su proyecto.

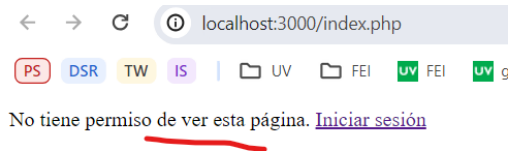


12. Para probar el funcionamiento de su aplicación, debe tener instalado la extensión **PHP Server** de Visual Studio Code. Abra su archivo `index.php`. En la parte superior derecha de su ventana de código, presione el icono de **PHP Server**. También puede ejecutar el comando `php -S localhost:3000`.



13. Se abrirá su navegador predeterminado en la página `index.php`.

14. Observe que no tiene permiso de ver esta página. Esto sucede porque no se ha creado el objeto de sesión en memoria del servidor y su correspondiente cookie en el lado del cliente.



15. Haga clic en el vínculo **Iniciar sesión**.

A screenshot of the 'Iniciar sesión' (Login) form on the Universidad Veracruzana website. The form is titled 'Iniciar sesión' and is part of the 'Programación Segura' section. It contains a text input field for 'Correo electrónico' (Email) with the value 'cuenta@uv.mx'. Below the input field, there is a small text note: 'Solo se permite el acceso con cuentas UV.' At the bottom of the form, there is a blue button labeled 'Siguiendo'.

16. Intente dejar en blanco el correo. Intente colocar un correo distinto del de UV, como **correo@gmail.com** o **correo@outlook.com** y de clic en el botón **Iniciar sesión**.

A screenshot of the 'Iniciar sesión' form. The email input field now contains 'correo@gmail.com'. Below the input field, there is a red error message: 'No es un correo válido institucional.' The blue 'Siguiendo' button is still at the bottom.

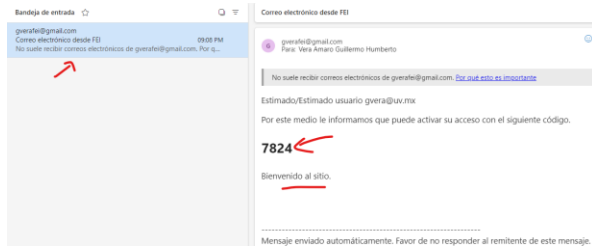
17. Al parecer la seguridad de la aplicación funciona tal como se espera. Ahora escriba su correo de la UV válido como **matricula@uv.mx**. Observe como se válida correctamente.

A screenshot of the 'Iniciar sesión' form. The email input field is now empty. Below it, there is a new section titled 'Código de seguridad' (Security code) with a text input field labeled 'Escriba el código de seguridad'. At the bottom, there are two buttons: a grey 'Regresar' button and a blue 'Entrar' button.

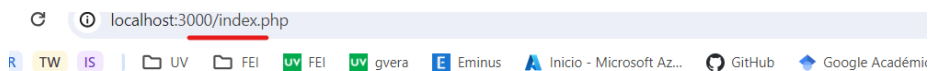
18. La aplicación ahora le solicita un código. Intente ingresar cualquier número o cadena. Observe como no le permite el acceso.

A screenshot of the 'Iniciar sesión' form. The security code input field is now filled with a value. Below the input field, there is a red error message: 'Código incorrecto'. The 'Regresar' and 'Entrar' buttons are still at the bottom.

19. En este momento, la aplicación ha validado su cuenta y envía un correo electrónico a esa cuenta válida con el código de acceso. **Revise su bandeja de correo electrónico.** Debería tener un código parecido a esto.



20. Regrese a la aplicación e introduzca el código recibido. Presione **Entrar** y observe como puede ingresar a la aplicación.



Sitio protegido Universidad Veracruzana



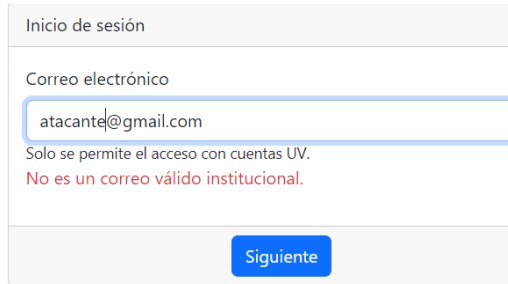
21. Si presiona el botón Cerrar sesión e intenta regresar a esta página, el mecanismo de autenticación no se lo permite. Al parecer la aplicación funciona de manera aceptablemente correcta y **solo permite a personal de la UV** entrar a ella.
22. Felicidades, ha creado su aplicación de manera correcta.

B. Explotar la vulnerabilidad

Lo primero que hace un atacante es revisar si hay puntos vulnerables en la **validación de entradas**.

En este ejemplo vamos a encontrar el punto de entrada de la vulnerabilidad al validar las cuentas de correo electrónico. Es muy común que la validación se haga intentando validar el dominio, que contenga el caracter arroba y al menos un punto. Sino se realiza correctamente esa validación múltiple, pueden presentarse vulnerabilidades de exposición de información confidencial a un actor no autorizado.

1. Vuelva a abrir la página de inicio de sesión.



Inicio de sesión

Correo electrónico

atacante@gmail.com

Solo se permite el acceso con cuentas UV.

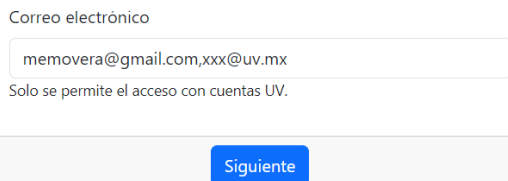
No es un correo válido institucional.

Siguiente

2. Usted quiere que le envíen el código a su correo de **atacante@gmail.com**, pero la validación no se lo permite. La validación también está del lado del servidor, por lo que una técnica de falsificación de solicitudes para saltarse la validación de cliente, no funcionará.
3. Lo que hace un atacante no es tratar de forzar la lógica de acceso, sino adaptarse a ella.
4. Introduzca el siguiente **payload** en el campo de correo electrónico.

atacante@gmail.com,xxx@uv.mx

5. Sustituya **atacante@gmail.com** por un correo válido distinto a la de la UV. Suponga que es su correo para perpetrar ataques a los sistemas.
6. La validación revisa que el correo termine con **@uv.mx** por lo que un **payload** de esta forma lo tomará como válido. Una simple “coma” es suficiente. Presione **Siguiente** y observe como lo deja pasar.



Correo electrónico

memovera@gmail.com,xxx@uv.mx

Solo se permite el acceso con cuentas UV.

Siguiente

7. Lo que ha sucedido aquí, es que debido al carácter “coma”, el sistema ha enviado dos correos: uno al atacante y otro al correo inexistente **xxx@uv.mx**.
8. Revise su bandeja de correo electrónico de atacante y debería tener el código de acceso para entrar al apartado privado.

Estimado/Estimado usuario memovera@gmail.com,xxx@uv.mx

Por este medio le informamos que puede activar su acceso con el siguiente código.

7824

Bienvenido al sitio.

9. Pruebe el código y observe como puede entrar al sistema.

Sitio protegido Universidad Veracruzana

Programación segura

Bienvenido a este sitio protegido por correo electrónico y un código de acceso.

Cerrar sesión

10. Esta técnica, que se mira tan sencilla, fue explotada durante muchos años por atacantes en varios sistemas web, por ejemplo, para resetear contraseñas de otros usuario. Incluso frameworks reconocidos como **Next.js**, en 2022 fue víctima de este ataque con tener vulnerabilidad en la detección de correos electrónicos válidos.
11. Felicidades, ha creado su aplicación de manera correcta.